MakeMyMarrige

UPDATED DETAILED PRODUCT REQUIREMENTS DOCUMENT

Version 2.0 | 3 November 2026

Kanpur, Uttar Pradesh, India

Product baseline for design, engineering, QA and release planning

1. Document control

Field	Value
Product	MakeMyMarrige
Document	Updated Detailed Product Requirements Document
Version	2.0
Date	3 November 2026
Status	Consolidated product baseline; infrastructure selections and open dependencies are explicitly identified
Launch market	Kanpur, Uttar Pradesh, India
Platforms	Responsive web application and installable PWA
Technology baseline	Next.js + TypeScript; NestJS + TypeScript API; MongoDB Atlas; Redis/BullMQ; private Cloudflare R2 object storage
Supersedes	Detailed PRD v1.4 and incorporates approved workflow decisions WF01–WF12 and multi-tenancy decisions MT-ADR-01

This document is the current product requirements baseline for product, UX, engineering, QA, security and release planning. It consolidates the product workflows and decisions finalised through WF01–WF12, plus the infrastructure and tenancy decisions recorded during architecture discussions. It supersedes earlier PRD drafts where requirements conflict. System design details are included only where they constrain product behaviour; implementation-level schemas, API contracts, indexes and runbooks belong in the System Design Document.

2. Product overview

2.1 Product vision

MakeMyMarrige is a family-first collaborative wedding planning platform. It gives a couple and their trusted organisers a controlled workspace to coordinate functions, tasks, households, guest invitations, RSVPs, vendors, budgets, expenses, Shagun contributions, photographs, notifications and audit history.

The initial launch targets weddings planned in Kanpur, Uttar Pradesh, India. The product is English-only, responsive and installable as a Progressive Web App (PWA).

2.2 Problem statement

Wedding planning information is commonly fragmented across calls, messaging applications, spreadsheets, notebooks and individual family members. This makes responsibility unclear, guest information inconsistent, financial decisions difficult to audit, and event changes hard to coordinate. MakeMyMarrige centralises the operational record while preserving family control and privacy.

2.3 Product principles

- Exactly two equal co-owners govern each wedding workspace.
- Least privilege: organisers receive only explicitly granted action-level permissions and scopes.
- Tenant isolation and privacy by default across all wedding data.
- Dual approval for high-impact governance, publication, finance and lifecycle decisions as specified in workflows.
- Clear distinction between estimates, vendor quotes, approved commitments, payments and incoming Shagun.
- Progressive setup rather than forcing every detail during initial onboarding.
- No claim of payment, vendor availability, delivery or deletion without authoritative confirmation.
- Auditable state changes and recoverable background processing.

3. Goals, non-goals and success measures

3.1 Goals

- Create and operate a private wedding workspace with exactly two equal co-owners.
- Invite organisers and assign granular, scoped permissions.
- Plan multiple wedding functions and coordinate tasks, checklists and dependencies.
- Maintain household-based guest records with individual invitation and RSVP state.

- Discover and manage vendors using authorised Google Places data and manually entered records.
- Track INR budgets, estimates, quotes, expenses, approvals, payment entries and reserve usage.
- Offer optional Digital Shagun through a provider-verified UPI payment flow, subject to provider and compliance readiness.
- Provide private wedding photo galleries with upload validation, moderation and controlled downloads.
- Provide role-specific dashboards, in-app notifications, audit history, exports and controlled lifecycle deletion.
- Offer an isolated fictional demo workspace and explain the one-time package price after the demo.

3.2 Non-goals for the initial release

- Vendor accounts, vendor dashboards, professional planner accounts or in-app vendor messaging.
- Automated WhatsApp or marketing email campaigns; operational wedding notifications remain in-app.
- Automated guest communication delivery or delivery tracking.
- Guest platform accounts; guests use wedding-scoped OTP verification and sessions.
- Public photo browsing, anonymous photo uploads, video uploads or person tagging.
- QR attendance check-in, seating charts, transport coordination, accommodation booking or livestreaming.
- Microservices, Kubernetes, Kafka, event sourcing, sharding or multi-region deployment for the pilot.
- Holding guest funds, storing payment credentials or presenting Shagun acknowledgements as bank/tax receipts.

3.3 Success measures

Track workspace activation, second co-owner acceptance, organiser adoption, task completion and overdue rates, RSVP completion, additional-guest request resolution, vendor shortlist progression, finance-record completeness, approved photo uploads/downloads, Shagun reconciliation outcomes, API availability, upload success, support incidents and verified deletion completion. Numerical targets and SLOs must be set after pilot baseline data; they are not assumed in this PRD.

4. Users, roles and account model

4.1 User categories

Actor	Description
Co-owner	One of exactly two equal owners of a wedding workspace.
Organiser	Trusted workspace member with explicit action-level permissions and optional resource scope.
Treasurer	A separate membership role appointed from an organiser; exactly one active Treasurer at a time.
Guest	A person represented in the wedding guest directory; no platform account is required.
Verified guest	A guest who has completed the wedding-specific OTP verification flow and holds a valid guest session.
Platform support operator	Internal support identity with no routine tenant-data access; temporary authorised access only.

4.2 Account and membership cardinality

- A global user account may have at most one ACTIVE or SUSPENDED wedding membership at a time.
- A user may have multiple historical membership periods over time, including membership in different weddings after a previous membership has ended.
- A suspended membership continues to occupy the one-membership slot. Suspension is not departure.
- A user with an existing ACTIVE or SUSPENDED membership cannot accept an invitation to another wedding. The new invitation remains valid and is not consumed by this conflict.
- No automatic transfer, removal, demotion or task reassignment occurs when a user attempts to join another wedding.
- Membership termination releases the active slot. A new invitation and normal acceptance checks are required to join another wedding.
- Global user accounts are not deleted merely because a membership or wedding workspace ends.

4.3 Roles and governance

- Every wedding has exactly two equal co-owner positions. The first co-owner creates the workspace; the second joins through an invitation.
- Organiser invitations are disabled until both co-owners are active.
- Organisers receive granular action-level permissions and resource scopes; permissions are checked server-side.
- Exactly one active Treasurer may be appointed. Treasurer is a distinct membership role, not an unrestricted finance administrator.
- Treasurer appointment, replacement and removal require approval by both co-owners.
- Organiser invitation, removal and other governance actions specified in WF02 require both co-owners' approval.
- A normal expense is approved by the Treasurer. A Treasurer-created or Treasurer-beneficiary expense requires both co-owners' approval. The creator cannot approve their own expense.
- If no Treasurer exists, normal expense approvals remain pending.
- Co-owners cannot use ordinary member-removal flows to remove or demote the other co-owner. Ownership recovery is a support-assisted process with identity and ownership checks.

5. Registration, authentication and invitations

5.1 Account capabilities

- Open registration with email/password and Google OAuth.
- Email verification is required before workspace creation or invitation acceptance.
- Login, logout, current-session inspection, password reset and verification resend.
- Secure server-managed sessions/tokens, rotating refresh tokens, secure HttpOnly cookies and CSRF protection where applicable.
- Users can view and revoke their own sessions.

5.2 Invitations

- Co-owner and organiser invitations use opaque, high-entropy, single-use tokens stored hashed at rest.
- Second co-owner invitation is bound to the exact invited email and expires after seven days; the first co-owner shares the link/code manually.
- The invitee must authenticate with the exact invited, verified email address.
- Organiser invitations are issued only after required governance approvals and both co-owners are active.
- Invitation preview must reveal only minimal information before authentication and eligibility checks.
- Expired, revoked, accepted or superseded invitations cannot be reused.
- Invitation acceptance is transactional, idempotent and audited.

5.3 Membership conflict handling

If the accepting account has an ACTIVE or SUSPENDED membership in another wedding, reject acceptance with HTTP 409 and a stable error code such as ACTIVE_WEDDING_MEMBERSHIP_EXISTS. Do not reveal the other wedding's identity or private information. Do not consume, revoke or shorten the pending invitation because of this conflict. The user must independently end the prior membership through an authorised process before retrying.

5.4 Security requirements

- Hash passwords with a modern password-hashing algorithm such as Argon2id or bcrypt using appropriate parameters.
- Never log raw invitation, verification, reset or refresh tokens.
- Use generic authentication responses where account enumeration is a risk.
- Apply layered rate limits to registration, login, verification and password reset.
- Account suspension and membership suspension are distinct controls.

6. Workspace creation and setup

- The first co-owner creates the workspace and first co-owner membership atomically.
- The second co-owner accepts the bound invitation; the acceptance transaction creates the second membership, marks the invitation accepted, updates workspace state and records an audit event.
- Workspace states include SETUP_IN_PROGRESS and TWO_CO_OWNERS_ACTIVE.

- Progressive setup collects essential wedding details first and allows later completion through a setup checklist.
- Workspace profile includes display name, couple names as supplied, primary city, wedding date, timezone and optional description.
- Initial market is Kanpur, Uttar Pradesh, India; one primary city per wedding is supported at launch.
- Use Asia/Kolkata for wedding-local dates and times. Store instants in UTC and retain date-only wedding values with explicit wedding timezone semantics.

7. Governance, organisers and permissions (WF02)

7.1 Governance approvals

- Organiser invitation and removal require both co-owners' approval.
- Treasurer appointment, replacement and removal require both co-owners' approval.
- Governance proposals use immutable snapshots/versioning. Any material modification invalidates previous approvals.
- Two distinct active co-owner accounts must approve. The initiator may count as the first approval.
- Governance requests have explicit states: REQUESTED, AWAITING_SECOND_APPROVAL, APPROVED, REJECTED, CANCELLED and EXPIRED. A seven-day expiry is the recommended default.
- The approved action executes atomically with the second approval; repeated requests must be idempotent.

7.2 Organiser permissions

Permissions are action-level and may be resource-scoped. Example permissions include dashboard.view; functions.view/create/update/publish/complete; tasks.view/create/assign/update/complete/reopen; guests.view/create/update/relationship_tags.manage; rsvp.view/assisted_update/correct; vendors.view/shortlist/update_status/enquiry.manage/quotes.manage/availability.manage/booking.manage; expenses.view/create; photos.view/upload/moderate; notifications.view.

Financial visibility is restricted to co-owners and the Treasurer. Organisers may see narrowly scoped information necessary to complete an explicitly authorised operation, such as their own submitted expense or a quote they are managing, but do not receive wedding-wide budget totals, expense ledgers or Shagun totals.

7.3 Suspension and removal

- Either co-owner may temporarily suspend a non-co-owner member during a suspected incident, with reason, audit event and notification to the other co-owner.
- Suspension immediately blocks access but does not release the user's active membership slot.
- Permanent organiser/Treasurer removal follows required dual approval. Access is revoked immediately after approval and membership becomes ENDED.
- Existing task assignments and historical records remain attributed to the former member; affected assignments are flagged for review/reassignment.
- A terminated member may later join another wedding through a new valid invitation.

8. Functions and task management (WF03)

8.1 Functions

- Support multiple predefined Indian wedding function templates and custom functions.
- Multiple functions may occur on the same day, including overlapping functions and different venues.
- Function fields include name, description, date/time, venue/address/map link, dress code, special instructions, invitees, RSVP settings, tasks and status.
- Function states: DRAFT, PUBLISHED, COMPLETED and CANCELLED.
- Publication and cancellation require both co-owners' approval.
- Published function snapshots are immutable; guest-facing pages show the current approved snapshot, never an unpublished draft.
- Venue visibility per function: ANNOUNCED, TO_BE_ANNOUNCED or PRIVATE.
- Completion may be performed by a co-owner or an authorised organiser.
- Cancellation preserves RSVP/task history and flags affected tasks for review. No automatic WhatsApp/email cancellation delivery.

8.2 Invitations and household eligibility

- Function invitations are issued at household level, with eligibility and RSVP maintained per individual guest.

- A new household member is not automatically invited to an existing function.
- A primary contact cannot submit RSVP for every household member by default.
- Additional guest requests are separate from original invitation records.

8.3 Tasks

- Tasks may be wedding-wide or function-specific, with multiple assignees and shared status.
- Fields include title, description, scope, function, assignees, creator, deadline, priority, status, checklist, dependencies, comments, progress and reminders.
- Task states: TO_DO, IN_PROGRESS, BLOCKED and COMPLETED.
- Completion requires mandatory checklist items and dependencies to be complete. Optional checklist items may remain incomplete.
- Progress is derived from mandatory checklist completion, not arbitrary manual percentages.
- Reopening requires explicit tasks.reopen permission and a reason; dependent tasks are flagged for review rather than silently undone.
- Dependencies cannot cross weddings; cycles are rejected. Comments are append-only/audited.
- Tasks survive function cancellation or member removal and are flagged for reassignment/review.

9. Guest directory, households and relationship tags (WF04)

- A household is an administrative grouping; each guest is an individual record.
- Co-owners and organisers with guest-creation permission can create households and guests.
- A guest may belong to only one active household within a wedding. A primary contact must be an active guest in the same household.
- Shared phone numbers are allowed. OTP proves control of a phone number, not the identity of every person sharing it.
- Primary contacts may edit only permitted contact details. Guest profile corrections are suggestions requiring authorised review; requester cannot approve their own suggestion.
- Guest merge requires both co-owners' approval. Organisers may flag suspected duplicates but cannot merge.
- Merge operations preserve invitations, RSVPs and audit history; large merges must be resumable and idempotent.
- Household transfer changes current household association but preserves historical invitations and RSVP records.
- Each guest may have one active primary relationship tag and multiple secondary tags. Relationship tags may include wedding side, related person, relationship type and custom label.
- Only co-owners and organisers with explicit relationship-tag permission can manage tags. Guest suggestions remain pending until reviewed.
- Relationship tags are private to authorised workspace members and never appear on public invitation pages.

10. RSVP and additional guest requests (WF05)

- RSVP is individual and self-service only for the verified guest; household-level verification does not authorise one person to respond for everyone.
- RSVP states: NOT_YET_RESPONDED, ATTENDING and NOT_ATTENDING.
- A guest may change their own response until the approved RSVP deadline.
- Both co-owners set or approve the RSVP deadline. Deadline changes/reopening require dual approval.
- After the deadline, guest self-service is locked. Unanswered invitations remain pending and are not auto-declined.
- Authorised organisers may perform assisted RSVP updates/corrections with the relevant permission, scope, reason and actor attribution.
- Household transfer preserves RSVP and invitation history.
- Additional guest requests have states PENDING_ARRANGEMENT, ARRANGEMENTS_CONFIRMED, CLOSED and CANCELLED.
- Partial approval is supported; requested, approved and outstanding counts remain distinct.
- Approval of an additional guest request does not silently create a guest record or invitation; those are explicit subsequent operations.
- Dashboards distinguish invited attending, declined, pending, additional requested, additional approved and outstanding. Avoid double counting.

10.1 Guest session

Guest OTP sessions are wedding-scoped, reusable until expiry or revocation, and restricted to the verified guest identity. A session cannot be used to access another wedding or another guest's records.

11. Vendor discovery and management (WF07)

- Use the official Google Places API through a provider adapter; no scraping. Initial discovery is limited to Kanpur.
- Support manual vendor records, visibly marked as manually entered.
- Categories include venues, photography, catering, decoration/florists, makeup, mehendi, music/DJs, clothing, transport, ceremony services, invitations/printing and other.
- Display only fields permitted by current provider terms and configured field masks; attribution and caching rules must be verified before production.
- Never invent prices, ratings, availability, reviews or claims. If price is unknown, show Contact for pricing.
- Vendor availability is explicit: NOT_CHECKED, AVAILABLE_CONFIRMED, UNAVAILABLE_CONFIRMED, TENTATIVE or UNKNOWN, with confirmation date. Never infer availability.
- Enquiry states: NOT_CONTACTED, CONTACTED, RESPONSE_RECEIVED, NEGOTIATING, SELECTED and REJECTED.
- Estimates support low/expected/high values and assumptions. Quotes separately record inclusions, exclusions, taxes, terms and validity.
- One selected vendor per service by default unless the service explicitly allows multiple.
- Co-owners and authorised organisers may shortlist. Either co-owner may select/remove; organisers cannot select/remove.
- Selection, quote or enquiry does not mean booking, contract, payment or confirmed availability. Vendor selection does not auto-create an expense.
- Organisers may manage enquiries/quotes/availability/booking records only with explicit permissions.

12. Budget and expense management (WF06)

- All money is stored as integer paise; display currency is INR.
- Total budget equals the sum of category allocations plus reserve; reserve is inside the total, not additional.
- Estimates support low/expected/high ranges and assumptions. Confirmed vendor quotes remain separate.
- Expense creation is available to co-owners and authorised organisers.
- Normal expense approval is by Treasurer only. If no Treasurer exists, the expense remains pending.
- Treasurer-created or Treasurer-beneficiary expenses require both co-owners' approval. Creator cannot self-approve.
- Category or total allocation changes require both co-owners' approval through immutable, versioned governance proposals.
- Reserve transfers are explicit and preserve total budget. Transfers above a configurable threshold require both co-owners' approval; related requests must not be split to evade the threshold.
- Pending expenses are shown as pending exposure, not approved commitments.
- Approved commitments exclude rejected, cancelled and voided expenses. Outstanding commitments equal approved commitments minus valid payments.
- Only Treasurer records payment entries. Multiple partial payments are supported; payment cannot exceed approved amount.
- Payment evidence is optional. Payment records are not silently edited/deleted; corrections use explicit adjustment/reversal records.
- Voiding/correcting an approved expense requires both co-owners' approval.
- Shagun is incoming funds and is not netted against budget, expenses or commitments.
- Reserve approval threshold remains configurable and must be set before production.

12.1 Expense states

DRAFT, PENDING_APPROVAL, APPROVED, REJECTED, PAYMENT_IN_PROGRESS, SETTLED, VOID_PENDING_APPROVAL, VOIDED and CANCELLED.

13. Digital Shagun (WF08)

- Digital Shagun is optional. Guests can skip it without affecting invitation access or RSVP.
- Treasurer submits one UPI destination configuration belonging to the couple. Both co-owners approve activation and every destination change.

- Shagun is unavailable until a valid configuration is approved.
- Guest identity must be verified. Anonymous contributions are not supported.
- Guest enters an amount and pays through a QR code or UPI app link, using a payment provider that supports actual funds flow to the couple's beneficiary and server-side verification.
- Only authenticated provider confirmation or a trusted provider-side status check can mark a contribution successful. Browser redirect, QR scan, client-side success, screenshot, guest claim or UPI reference alone is not proof.
- Delayed webhook reconciliation may be initiated by the Treasurer, but the backend must verify status with the provider. Treasurer cannot manually mark a contribution successful.
- Provider events exclusively control reversal/refund status where supported. Multiple contributions are allowed subject to provider limits.
- Guest sees only their own contribution history. Co-owners and Treasurer see the full ledger. Organisers and other guests see no ledger.
- No public donor list or contribution amounts. Shagun entry point appears on the main wedding page, not function pages.
- Platform acknowledgement is issued only after verified success and is not a bank receipt, tax receipt or claim of tax deductibility.
- The platform does not hold funds and never collects UPI PINs, payment OTPs or banking passwords.
- Payment provider selection, beneficiary onboarding, settlement, fees, reversals, refunds, disputes and applicable Indian regulatory review are production blockers.

14. Photo gallery and moderation (WF09)

- Create one album automatically per function; gallery is wedding-scoped and contains photos only in v1.
- Co-owners and organisers with upload permission have uploads auto-approved after technical validation.
- Guest uploads always require moderation by co-owners or organisers with photos.moderate permission.
- All verified wedding guests and workspace members may view/download approved photos from every function, even if not invited to that function.
- A guest may upload only to a function to which that individual guest was invited.
- Guests cannot delete photos. They may request removal; only co-owners decide guest removal requests and permanent removal.
- Authorised moderators may temporarily hide/restore published photos. Permanent removal is a co-owner decision.
- Guests may report published photos. Reports and removal requests do not automatically hide or delete a photo.
- Optional captions are supported; no person tagging in v1.
- Remove GPS EXIF and unnecessary metadata before publication. Validate actual file type/content, size, batch/session and quota limits; scan where feasible; generate derivatives.
- Use private object storage and short-lived authorised URLs. Every view/download must be authorised. Do not cache protected originals or signed URLs for offline PWA access.
- Photo states: PENDING_REVIEW, APPROVED, REJECTED, HIDDEN and REMOVED.
- Workspace deletion includes originals, derivatives, metadata and temporary uploads.

15. Dashboards and notifications (WF10)

- Provide separate fixed-layout dashboards for co-owners, organisers and Treasurer.
- Financial visibility is restricted to co-owners and Treasurer. Organisers receive only narrowly scoped operational financial information where explicitly required.
- Guest/RSVP metrics are aggregated by default; individual details require relevant permissions.
- Alert priorities: Critical, High, Medium and Informational.
- Notifications are in-app only for wedding operations. Email is reserved for transactional account/security messages.
- Users can mark notifications read/unread and control selected notification categories.
- Notifications are individual; no grouping in v1. Retain notifications until workspace deletion.
- Initial delivery uses polling/refresh; WebSockets are not required for pilot.
- Notifications are generated from successful domain events, idempotently. Deep links re-check permission at destination.
- Metric definitions: countdown uses wedding-local date; active functions exclude cancelled; invited guests are distinct individuals; task completion uses completed eligible tasks divided by total eligible non-cancelled tasks; financial commitments exclude rejected/cancelled/voided; outstanding equals commitments minus valid payments; reserve remaining equals allocation minus

approved reserve usage.

- Avoid misleading percentages when denominators are zero.

16. Audit, security and workspace administration (WF11)

- Audit significant security, governance, financial, guest, vendor, task and photo changes. Routine page views are excluded.
- Audit logs are visible only to both co-owners. Both co-owners can export CSV/PDF.
- Application-level audit records are append-only; users cannot edit or delete them.
- Record sensitive reads/exports where appropriate. Redact secrets and unnecessary personal data from audit payloads.
- Users can view/revoke their own sessions. Co-owners can revoke workspace access through approved controls.
- Either co-owner may temporarily suspend a non-co-owner member during suspected incident; reason, audit and notification to the other co-owner are required.
- Support-assisted workspace recovery requires identity and ownership checks and cannot create an unofficial third owner.
- Maintain structured security incident records with severity SEV_1–SEV_4 and lifecycle DETECTED, TRIAGED, CONTAINMENT, INVESTIGATION, RESOLUTION and CLOSED.
- Personal data access/correction requests follow controlled review; requester cannot approve their own request and review cannot bypass guest identity or workspace rules.
- Audit retention follows workspace lifecycle and deletion requirements.

16.1 Audit integrity qualification

Application-level append-only controls do not make audit records tamper-proof against privileged database operators. Stronger assurance may use hash chaining or signed checkpoints and protected backups. This is an implementation/security enhancement, not a claim of absolute immutability.

17. Workspace lifecycle, cancellation and deletion (WF12)

17.1 Post-wedding lifecycle

- The wedding date is the source of truth. Workspace automatically enters POST_WEDDING after the wedding date.
- Permanent deletion is due at 00:00 Asia/Kolkata on day 31 after the wedding date. Example: wedding date 1 November 2026 → deletion due 2 December 2026 at 00:00 IST.
- Wedding date changes after the original date has passed require both co-owners' approval and are allowed only before permanent deletion starts.
- The deletion worker rechecks the currently approved wedding date and lifecycle state before execution.

17.2 Cancellation

- Cancellation requires both co-owners; the second approval is final and irreversible.
- Immediately revoke member and guest access, invitation links, public pages, RSVP and upload access, and active sessions.
- Show only a generic cancellation notice for seven days; private workspace data and original public pages are unavailable immediately.
- Create an asynchronous, retryable deletion operation. Cancellation cannot be reversed.

17.3 Deletion

- Deletion is an idempotent, retryable background workflow with explicit operation states QUEUED, IN_PROGRESS, RETRY_PENDING, BLOCKED, COMPLETED and FAILED_REQUIRES_REVIEW.
- Freeze writes, revoke access, stop scheduled jobs, delete object storage originals/derivatives, delete domain records and derived data, request supported external-provider cleanup, and verify completion.
- Do not mark deletion complete until all required cleanup steps are verified or formally documented as an external/legal exception.
- Maintain a minimal deletion tombstone so restored backups cannot reactivate a deleted workspace. Replay tombstones before a restored environment is made live.
- Backup target of no more than 30 days is proposed, subject to provider capabilities and legal review. Backups are encrypted/restricted; deletion from backups follows documented expiry, not an unsupported claim of immediate erasure.
- Both co-owners may request one final export before cancellation's second approval. Export cannot delay cancellation or deletion. Ordinary completion exports are available before deletion deadline.
- External providers may retain records under their legal/provider policies; request deletion where supported and document exceptions.

18. Multi-tenancy and tenant isolation (MT-ADR-01)

18.1 Tenant model

- One wedding workspace is one tenant.
- Use a shared MongoDB Atlas database and shared collections with logical tenant isolation for the pilot.
- Every tenant-owned record carries weddingId or is reachable only through a validated tenant-scoped relationship.
- Global user identity is separate from wedding membership. A membership connects one user to one wedding and determines role/status/permissions.
- One user may have at most one ACTIVE or SUSPENDED membership at a time. Multiple historical membership periods are allowed.
- Membership termination releases the active slot; rejoining requires a new valid invitation/acceptance. Same-wedding rejoin reuses the membership record and records a new membership period in append-only history.

18.2 Tenant resolution and enforcement

- NestJS resolves tenant context server-side from authenticated identity and validated active membership; frontend-supplied weddingId is never authoritative.
- Protected requests validate account status, membership status, role, permissions and resource scope.
- Use tenant-scoped repository interfaces; every query, update, delete and aggregation must include tenant scope.
- Validate that referenced resources belong to the same wedding. Cross-tenant references are rejected.
- Tenant context propagates to Redis keys, BullMQ jobs, R2 object access, caches, notifications, exports and audit queries.
- Workers validate tenant and resource relationships before processing sensitive jobs.
- A unique partial MongoDB index enforces at most one ACTIVE or SUSPENDED membership per user. Concurrent invitation acceptance must be transactionally safe and return HTTP 409 on conflict.
- Guest identity and guest session are separate, wedding-scoped models. Shared phone numbers do not merge identities.
- Platform support has no routine unrestricted tenant access. Temporary break-glass access is scoped, approved, time-limited, read-only by default and audited.
- Future migration to isolated tenant databases remains possible through tenant-aware repository boundaries and a tenant storage registry when justified; database-per-wedding is not implemented for pilot.

18.3 Cross-tenant security acceptance

- Changing URL, request body, header, query parameter, object key or resource ID must not grant cross-tenant access.
- A task in Wedding A cannot reference a function in Wedding B.
- A guest session from Wedding A cannot access Wedding B, even if the same phone number is present.
- A suspended member cannot accept another wedding invitation; the suspended membership continues to occupy the active slot.
- Cross-tenant access tests cover controllers, repositories, workers, cache, files, exports and dashboards.

19. Infrastructure and platform requirements

19.1 Confirmed technology direction

Layer	Direction
Frontend	Next.js + TypeScript; responsive web and installable PWA
Backend	Separate NestJS + TypeScript API; modular monolith
Database	MongoDB Atlas
Queue/cache	Redis with BullMQ; API and worker are separate processes using shared backend code
Object storage	Private Cloudflare R2 bucket; direct browser uploads using NestJS-issued presigned URLs; short-lived authorised downloads
Vendor discovery	Google Places API behind an adapter
Payments	UPI payment provider adapter; provider not selected
Email	Brevo recommended for transactional account/security email; plan and exact quota/cost to be verified

Layer	Direction
Rate limiting	Cloudflare edge protection plus Redis-backed NestJS identity-aware limits
Redis operations	Managed Redis service; provider/region/capacity to be selected
Hosting	Managed split deployment recommended for pilot; exact providers/regions remain open

19.2 Object storage requirements

- R2 bucket is private. MongoDB stores metadata and object keys, not binary image content.
- Direct upload uses short-lived presigned PUT URLs issued by NestJS. Completion endpoint verifies object existence, size and checksum before processing.
- A worker validates content, strips GPS/unnecessary EXIF and generates derivatives before setting photo state to PENDING_REVIEW or APPROVED.
- Object key structure is wedding-scoped, e.g. weddings/{weddingId}/functions/{functionId}/photos/{photoId}/original.
- Signed GET URLs are issued only after tenant and permission checks and should be short-lived (recommended starting point: approximately five minutes).
- India-only data residency is not guaranteed by the current R2 location preference; Asia-Pacific placement is a preference, not a residency guarantee. Verify provider placement and legal requirements before production.

19.3 Rate limiting and abuse protection

- Cloudflare provides edge DDoS/WAF/coarse IP controls; NestJS provides endpoint-specific identity-aware policies; managed Redis provides shared atomic counters and expiry.
- Initial strict pilot defaults: login 5 failed attempts/15 minutes (account + IP); registration 3/hour/IP; password reset 3/hour/account; verification email 3/hour/account; OTP send 3/10 minutes and 5/hour per phone; OTP verification 5/challenge; invitation acceptance 5/15 minutes/IP; guest RSVP 10/10 minutes/guest; upload initiation 5/10 minutes/user or guest; upload completion 10/10 minutes; photo reports 5/hour/guest; authenticated API 60/minute/user; public reads 30/minute/IP, with route-specific exceptions.
- These are initial defaults, not immutable requirements. Tune through load tests and false-positive monitoring. Avoid broad IP blocks that punish shared household/mobile-carrier networks.
- Return HTTP 429 and Retry-After. Login failures use cooldown/progressive delay rather than permanent account lockout.
- Redis failure policy is hybrid: fail closed for authentication, OTP, email-triggering and upload-sensitive operations; ordinary reads may use conservative per-instance emergency limits, recognising that these are weaker than distributed enforcement.
- Protect email and OTP provider quotas separately from API limits.

19.4 Email and notifications

- In-app notifications are used for wedding operations. Email is reserved for transactional account/security messages: verification, password reset, invitations and security/account changes.
- Use a durable MongoDB transactional outbox as the source of truth; BullMQ/Redis delivers work. An outbox dispatcher republishes jobs if Redis loses them.
- Brevo is the recommended initial email provider, but exact paid tier, quota and pricing must be verified before production. At a target near 300/day, the free tier has no headroom.
- Use provider webhooks for delivery/bounce/blocked status. Provider acceptance does not equal delivery. Authenticate webhooks, process idempotently and never log tokens.
- Separate priorities for security-critical, verification, invitation and low-priority messages; apply provider throughput and daily/monthly budgets.

19.5 Reliability and operations

- API and worker are separate processes in one modular backend codebase; do not introduce microservices for the pilot.
- Use transactions for cross-document invariants; MongoDB deployment must support transactions.
- Redis is not the source of truth for business records. Queue jobs must be idempotent and recoverable from durable outbox records.
- Use structured logs, correlation IDs, metrics, alerts, backups, restore tests and operational runbooks.
- Exact hosting, MongoDB region, Redis provider/region, OTP provider, payment provider, backup schedule, SLOs and monitoring vendor remain production decisions.

20. Privacy, security and compliance

- Deny by default and enforce authentication, tenant isolation, RBAC and resource policy server-side on every protected operation.
- Use TLS in transit, secure secrets management, strict CORS, security headers, input validation, output encoding and protection against injection, XSS, CSRF, IDOR and mass assignment.
- Keep household contact details, RSVP responses, financial records, Shagun ledger and audit exports private.
- Use private object storage and authorisation checks on every media read/download.
- Do not collect or store UPI PINs, bank passwords or payment OTPs.
- Document purpose, consent, privacy notice, data minimisation, retention, processor terms and applicable Indian data-protection/payment obligations before production.
- Review Google Places attribution, field masks and caching terms before release.
- Document backup expiry and provider retention limitations. Do not claim instant erasure from provider backups where that is not supported.

21. Non-functional requirements

Quality attribute	Requirement
Performance	Use appropriate indexes, pagination, cursor-based navigation for large lists, optimised image derivatives and background processing. Establish measurable latency targets after pilot baselines.
Availability	Define pilot and production SLOs after hosting/provider selection.
Scalability	Support growth in workspaces, guests, tasks, photos and concurrent users without cross-tenant leakage.
Reliability	Retryable and idempotent jobs for email, reminders, media processing, webhooks, exports and deletion.
Security	Server-side authorization, tenant isolation, private storage, rate limits, audit and secure sessions.
Usability	Mobile-first responsive flows, progressive setup, role-aware navigation and clear state labels.
Accessibility	Semantic controls, keyboard navigation, labels, sufficient contrast and accessible error states.
Maintainability	Modular domain boundaries, typed contracts, automated tests, migrations and runbooks.
Data integrity	Integer paise, validated same-tenant references, controlled state transitions and concurrency protection.

22. Acceptance criteria and release gates

22.1 Product acceptance

- A user can register, verify email and create/join no more than one active or suspended wedding membership.
- A wedding has exactly two equal co-owners; organiser invitations are disabled until both are active.
- Governance approvals execute only after required distinct co-owner approvals.
- Organiser permissions are action-level, scoped and enforced server-side.
- Functions, tasks, guest directory, household invitations, individual RSVPs and additional guest requests follow the defined state rules.
- Budget invariants, Treasurer approvals, co-owner exceptions, payment entries and reserve calculations are correct.
- Vendor records distinguish manual data, Places data, estimates, quotes, availability, selection and booking.
- Shagun success is based only on trusted provider verification; guest and workspace visibility rules are enforced.
- Guest photo uploads require moderation; member uploads auto-approve only after technical validation; approved media is private and authorised.
- Role-specific dashboards and in-app notifications expose only permitted data.
- Audit logs are co-owner-only and exports are authorised and audited.
- Cancellation and post-wedding deletion are idempotent, retryable and verified.

22.2 Security acceptance

- Automated cross-tenant tests attempt ID substitution across every tenant-owned API and resource type.
- Concurrent membership invitation acceptance cannot create two ACTIVE/SUSPENDED memberships.
- A user with an existing Wedding A membership cannot accept Wedding B invitation; Wedding B invitation remains unconsumed.
- Suspended membership continues to occupy the membership slot.
- Guest sessions cannot cross wedding or guest boundaries.
- Workers, Redis keys, caches, R2 files, exports and audit queries preserve tenant context.
- Redis failure follows the documented hybrid rate-limit policy.
- No client-side payment claim can mark Shagun successful.
- Deletion tombstones prevent deleted workspaces from reappearing after backup restoration.

22.3 Production blockers

- Select and validate OTP provider, channel, delivery cost, expiry, resend and guest-session policy.
- Select UPI payment provider and validate beneficiary onboarding, settlement, server-side confirmation, webhook security, reconciliation, fees, refunds/reversals and disputes.
- Confirm Cloudflare R2 placement and whether any India data-residency requirement can be met.
- Select hosting and MongoDB/Redis regions; validate network security, transaction support, backup/restore and deletion behaviour.
- Verify Google Places API terms, field masks, attribution and caching.
- Set reserve approval threshold, operational quotas, file limits and storage limits.
- Complete applicable Indian legal/privacy/payment review and publish notices/terms.
- Set SLOs, monitoring/alerting, incident response and support recovery procedures.

23. Suggested delivery sequence

Phase	Scope	Exit criteria
1. Foundation	Repository, environments, identity, tenant resolution, membership, workspace, invitations, permissions and audit foundation.	Auth, membership concurrency, tenant isolation and role tests pass.
2. Planning core	Wedding profile, functions, tasks, dependencies and role dashboards.	Core planning flows work on mobile and desktop.
3. Guest operations	Households, guest directory, relationship tags, invitations, OTP, RSVP and additional guest requests.	Guest privacy, tenant isolation and RSVP acceptance tests pass.
4. Vendors and finance	Places discovery, vendor records/quotes, budgets, Treasurer, expenses and payment records.	Financial invariants and Places policy validated.
5. Memories and operations	R2 upload pipeline, moderation, gallery, notifications, exports, incident tools and deletion.	Media security, moderation and deletion verification pass.
6. Shagun and release hardening	Payment provider integration, reconciliation, demo, PWA, observability, backups and security/legal review.	Provider/compliance blockers closed; production readiness sign-off.

24. Risks and mitigations

Risk	Mitigation
Cross-tenant data exposure	Server-resolved tenant context, tenant-scoped repositories, same-tenant relationship validation and automated adversarial tests.
Co-owner deadlock	Dual-approval flows, immutable history and documented support escalation; no unofficial third owner.
Membership race condition	MongoDB unique partial index and transactional invitation acceptance.
Household enumeration or identity confusion	OTP before reveal, generic errors, rate limits and individual guest identity.
Budget arithmetic or approval error	Integer paise, invariant tests, immutable finance events and explicit approval states.
Payment misrepresentation or reconciliation failure	Provider-side verification, signed webhooks, idempotency and reconciliation; no manual success override.

Risk	Mitigation
Vendor data policy breach	Official Places API, field/attribution/caching compliance and explicit unknown values.
Photo abuse or privacy incident	Guest moderation, reporting, private storage, EXIF stripping, quotas and co-owner removal.
Storage or provider cost growth	Rate limits, quotas, daily budgets, derivatives, monitoring and lifecycle deletion.
Incomplete deletion or backup resurrection	Idempotent deletion manifest, retries, tombstones, restore tests and provider cleanup tracking.
Strict rate limits block legitimate families	Layered identity/IP limits, shared-network awareness, monitoring and controlled tuning.

25. Open decisions and assumptions

The following are not silently treated as settled:

- OTP provider, channel, pricing, expiry, resend policy and guest-session lifetime.
- UPI payment provider, beneficiary/merchant onboarding, settlement, fees, refunds, reversals, disputes and regulatory obligations.
- Hosting provider and region; MongoDB Atlas region; managed Redis provider, region, capacity and availability terms.
- Cloudflare plan/features and origin network restrictions.
- R2 location/residency guarantees, account pricing, backup and lifecycle settings.
- Exact email provider paid tier and 10k/month-or-higher capacity pricing; Brevo is the recommendation, not a final commercial commitment.
- Reserve approval threshold; photo file formats, file-size/batch limits, per-wedding quotas and processing concurrency.
- Organiser permission presets and exact resource-scope UX.
- Support recovery evidence requirements and escalation authority.
- Legal review of applicable Indian privacy, consent, retention, payment and processor obligations.
- Numerical success targets, SLOs, support response targets and production capacity assumptions.

The strict initial rate-limit values and suggested infrastructure settings in this document are pilot defaults/recommendations. They must be validated with load tests, provider constraints and observed false positives before production.

26. Glossary

Term	Definition
Tenant	One wedding workspace and its isolated data/access boundary.
Workspace	Private planning environment for one wedding.
Membership	Relationship connecting a global user account to one wedding, with role, status and permissions.
Co-owner	One of exactly two equal workspace owners.
Organiser	Workspace member with granular, scoped permissions.
Treasurer	Single appointed membership role for permitted finance operations.
Guest	Individual represented in a wedding guest directory; no platform account required.
Verified guest	Guest with a valid wedding-scoped OTP session.
Function	A wedding event such as ceremony, reception or pre-wedding event.
Household	Administrative grouping of guests with a primary contact.
Commitment	Approved financial obligation; not necessarily paid.
Reserve	Part of total wedding budget set aside for unexpected costs.
Outbox	Durable record of an event/job to be delivered asynchronously.
Break-glass access	Temporary, approved, audited exceptional support access.

Appendix A. Version 2.0 change summary

- Consolidates finalised workflows WF01–WF12 into a single PRD baseline.
- Replaces the earlier one-wedding-ever account interpretation with one ACTIVE or SUSPENDED membership at a time; historical membership periods and rejoining are supported.
- Defines no automatic transfer: Wedding B invitation acceptance is rejected with HTTP 409 while a Wedding A membership is ACTIVE or SUSPENDED; the new invitation remains unconsumed.
- Adds shared-database logical multi-tenancy, server-resolved tenant context, tenant-scoped repositories, cross-tenant controls and a future isolation migration path.
- Adds confirmed infrastructure direction for NestJS, managed Redis, Cloudflare edge protection, BullMQ, private Cloudflare R2, transactional outbox and layered rate limiting.
- Separates confirmed decisions from recommendations and production blockers, including OTP, payment, hosting, provider pricing and residency.